Incident management and response Research and State of the Art

Joakim Kävrestad
Jönköping School of Engineering
joakim.kavrestad@ju.se

© Crown Copyright, The National Cyber Security Centre 2023. This information is licensed under the Open Government Licence v3.0. To view this licence, visit https://www.nationalarchives.gov.uk/doc/open-government-licence/version/3/.

When you use this information under the Open Government Licence, you should include the following attribution: CyBOK memory analysis workshop slides © Crown Copyright, The National Cyber Security Centre 2023, licensed under the Open Government Licence: https://www.nationalarchives.gov.uk/doc/open-government-licence/version/3/.

This lecture

- This lecture will focus on current challenges and what the research has to offer
- With a continuously developing area, new things are happening all the time
- The idea here is to discuss some of the current trends related to incident management and response

Litterature note

- The purpose of this lecture is to bring attention to some RnD areas

- The lecture is primarily built on the following publications:
  - Stevens, R., Votipka, D., Dykstra, J., Tomlinson, F., Quartararo, E., Ahern, C., & Mazurek, M. L. (2022, April). How ready is your ready? assessing the usability of incident response playbook frameworks. In *Proceedings of the 2022 CHI Conference on Human Factors in Computing Systems* (pp. 1-18).
  - Kearney, P., Abdelsamea, M., Schmoor, X., Shah, F., & Vickers, I. (2023). Combating Alert Fatigue in the Security Operations Centre. *Available at SSRN 4633965*.
  - Alahmadi, B. A., Axon, L., & Martinovic, I. (2022). 99% False Positives: A Qualitative Study of {SOC} Analysts' Perspectives on Security Alarms. In *31st USENIX Security Symposium (USENIX Security 22)* (pp. 2783-2800).

Litterature note

- The lecture is primarily built on the following publications (cont):
  - Hranický, R., Breitinger, F., Ryšavý, O., Sheppard, J., Schaedler, F., Morgenstern, H., & Malik, S. (2021). What do incident response practitioners need to know? A skillmap for the years ahead. *Forensic Science International: Digital Investigation*, *37*, 301184.
  - Vielberth, M., Böhm, F., Fichtinger, I., & Pernul, G. (2020). Security operations center: A systematic study and open challenges. *IEEE Access*, *8*, 227756-227779.
  - Shaked, A., Cherdantseva, Y., Burnap, P., & Maynard, P. (2023). Operations-informed incident response playbooks. *Computers & Security*, *134*, 103454.

Agenda

- SOC open challenges
- Knowledge requirement for incident response professionals
- Playbooks
- Alert fatigue

SOC open challenges

CyBOK

- SOC has been a well-known concept for about 20 years and has grown in the past 10ish years; they are relatively new
- Both research and best practices are fragmented and quite immature
- Lets begin with a few open challenges

SOC open challenges

CyBOK

- Many tasks in a SOC are monotonous and repetitive
  - Alert fatigue – more on that later
  - Time consuming and boring
  - Improving alert rates is one important area of development
  - Gamifying the SOC is another suggestion for making the job more engaging

- Integration of domain knowledge
  - Identifying known threats by signatures is quite easy
  - Detecting the unknown is hard and requires domain-specific knowledge and CTI, which can be challenging to integrate into the SOC

SOC open challenges

CyBOK

- The skills gap
  - A lot of different skills are needed in a SOC
  - Finding staff with the right skillset is hard

- Collaboration is lacking
  - There is a lack of good collaboration platforms, which leads to a lack of collaboration
  - Collaboration between analysis is thought to improve SOC performance

SOC open challenges

CyBOK

- Need for defined processes
  - It is hard to find precise definitions of what a SOC is, which means that it is hard to fully understand and develop them
  - Also, define how a SOC should relate to other security processes

- Increased technical complexity
  - Our systems are growing in size and complexity
  - The capability need for an effective SOC also grows

SOC open challenges

CyBOK

- Tools, so many tools
  - A SOC does require quite a few tools (or at least functionalitites)
  - The tools needs to be maintained, which presents a problem of its own
  - A second problem is communication between tools

- Data visualization
  - Analysts are exposed to a lot of data (alerts, logs, CTI….)
  - Finding good ways to present that remains an open challenge

Skills gap!

CyBOK

- SOC analysts and incident responders are expected to know a lot
  - Operating systems
  - Networks
  - Bit of forensics
  - Cloud
  - IoT
  - ….

- Finding those people is hard, even finding suitable education is hard

Skills gap!

- A SOC needs to have competence in all technologies it monitors
  - Often, job ads suggest that every worker should hold those
- To what extent that is possible (or reasonable) can be questioned
  - Maybe we instead need more different roles
- A second issue is the gender imbalance
  - Getting more women into the SOC would make for a larger workforce

REFLECT!

- Use one minute to write down one-liners that reflect what you learned so far.
- Join up in pairs or groups and compare your lists for another minute.
- Questions so far?

Playbooks

- Playbooks are step-by-step guidelines for how to handle different incidents
- The idea is that you have a pre-created plan to follow in different scenarios, which intends to increase work efficiency
- Research suggests that playbooks have not been evaluated based on their effectiveness

Playbooks

- Using a playbook design framework can help create uniform and complete playbooks
  - Two examples of such frameworks are presented by NIST and IACD (see Stevens et al. 2022)

- Stevens et al (2022) while suggesting that the NICS and IACD frameworks an insufficient, outline a number of requirements for good playbooks

Playbooks – good practise

CyBOK

- Easy to select and comprehend
  - The whole point is to make incident response easy, and then the playbook itself should be easy to both identify for the case, and to use
- Should provide details
  - A playbook should not assume that a user is familiar with technologies but outline how they should be operated
- Link to outside resources
  - Finding the right amount of information is tricky. It is useful to link to extended information

Playbooks – good practise

CyBOK

- Prompt regular communication
  - Communication is crucial during incident response and the playbook should outline what needs to be communicated and to whom

- Provide intent instead of just action
  - When a playbook just states what to do it can be hard for the user to understand why
  - Including intent remedies that, and make the playbook a learning instrument

Playbooks – good practise

- Stevens et al (2022) also outlined some good advice not directly related to playbooks:
  - Tabletop exercises are good for training and for identifying playbook gaps
  - Improving perceived playbook usefulness can increase adoption
  - Organizational constraints can impact playbook design

Playbooks – good practise

CyBOK

- Stevens et al (2022) also outlined some good advice not directly related to playbooks:
  - Tabletop exercises are good for training and for identifying playbook gaps
  - Improving perceived playbook usefulness can increase adoption
  - Organizational constraints can impact playbook design

- A second research direction, pursued by Shaked et al (2023) is on how playbooks relate to operational impact.
  - The argument is that highlighting how an incident impacts an organization's operations help management understand incident response and cyber risk, and is ultimately beneficial for security operations.

Playbooks – operational perspectives

- Explaining the possible effects of a cyber incident, and incident response, to management is important
  - Understanding
  - Funds
  - …
- Management struggles with understanding cyber risks
- Incident response is nevertheless typically a technical matter

Playbooks – operational perspectives

- Shaked et al (2023) propose a model for integrating operations into playbooks

- They argue for a number of benefits:
  - Promotes the ability to communicate the playbooks with different stakeholders
  - Allows management to be included in playbook design and provide an operative perspective

REFLECT!

- Use one minute to write down one-liners that reflect what you learned so far.
- Join up in pairs or groups and compare your lists for another minute.
- Questions so far?

False positives

- Alahmadi et al (2022) research the topic of false positives, alarms raised for benign situations

- False positives create an unnecessary burden on analysts who manually need to review harmless events
  - Increases human error (Cry wolf effect)
  - Increases fatigue and burnout

False positives

- Alahmadi et al (2022) conducted an interview study with SOC analysts on the topic of false positives

- On alarm validation
  - Tools are good for pointing in the right direction (raising alarms) but not so good at evaluation, which comes down to the analyst
  - There are many tools, but one should remember that all tools need configuration and maintenance
  - Knowledge of the specific environment impact alert assessment greatly

False positives

- On false positives
  - The number of false positives is high, someone claimed 99% or all alarms are false
  - What a false positive actually is is not completely clear. Consider malicious traffic that is decided to be ignored
  - Difference between noice and benign triggers

- On Alarm reliability
  - ID/PS systems are seen as noisy, often because of the way rules are written
  - SIEMs can produce better alarms because of correlation capabilities, but still rely on data from ID/PS

False positives

- On alarm explainability
  - Propietary tools often produce alarms but hide the reason for the alarm which require the analysts to research further
  - Contextual knowledge such as understanding business hours, as well as CTI helps evaluate alerts

- Give us better tools!
  - Improving tools and their configuration is naturally something that is wanted
  - AI was discussed as a potential avenue but some interview participants suggested that what they tested still produced high false positive rates

Alert fatigue

CyBOK

- Connected to False positives is Alert fatigue, which was discussed by Kearney et al (2023)
  - *“the SOC analyst is effectively blinded by the sheer volume of system-generated messages demanding attention, most of which turn out not to have security significance.”*

- Many reasons interplay
  - Increased number of incidents
  - High false positive rates
  - Skills gap

Alert fatigue

CyBOK

- Kearney et al (2023) propose supporting SOC analysts with an AI assistant

- In their research, they
  - Outline requirements for such an assistant
  - Show how it can be implemented

Alert fatigue

CyBOK

- A problem with using ML for classification is that while ML is good as seeing correlations, it is not so good at understanding causalities
- Using the AI assistant, the model will only make decisions when very confident and involve the analysts in other cases
  - The outcome of analyst decisions will train the model further
- The approach is currently tested, and early feedback is positive

Thank you for today!